COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.2 · Impersonation

Mestre CyberSec · **Aula 2.2 — Impersonation** (5:52) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Roubo de identidade na conversa: BEC (Business Email Compromise — 'falo pelo CEO'); tailgating (entrar na porta atrás da pessoa); shoulder surfing (olhar sobre o ombro); dumpster diving (papel na lixeira); brand impersonation (falso suporte).

💡 Highlights que a prova CompTIA cobra

- BEC: o email SE PASSA pelo executivo (vítima interna)
- Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC
- Tailgating: entra na porta atrás de quem tem acesso

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'sender claims to be an executive' = BEC
- 'follows an authorized person through a door' = tailgating/piggybacking

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.2 — Impersonation)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Comprometimento de E-mail Corporativo (BEC)

Ataque de engenharia social em que o atacante se passa por um executivo confiável (geralmente CEO/CFO) via e-mail para induzir um funcionário interno a transferir fundos ou compartilhar dados sensíveis.

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'sender claims to be an executive asking for a wire transfer' = BEC. Vítima é interna (funcionário), não o executivo.*

• Whaling (Caça à Baleia)

Ataque de phishing altamente direcionado especificamente a executivos de alto escalão (C-level, diretoria) para roubar credenciais, autorizar transações fraudulentas ou obter dados estratégicos.

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'phishing targeting the CEO/CFO directly' = Whaling. NÃO confunda com BEC — em Whaling o executivo é a VÍTIMA, em BEC o executivo é o IMPOSTOR.*

• Tailgating (Rabo-colado)

Engenharia social física em que uma pessoa não autorizada segue um indivíduo autorizado através de um ponto de acesso controlado (porta, portão) sem apresentar credenciais.

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'follows an authorized person through a door' = Tailgating. Sinônimo: piggybacking (mesma técnica na prova).*

• Piggybacking (Carona)

Semelhante ao tailgating, mas a pessoa autorizada conscientemente permite que o indivíduo não autorizado passe pelo ponto de acesso (frequentemente por cortesia).

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'person holds the door open for someone behind them' = Piggybacking. Na prova, tailgating e piggybacking são usados como sinônimos.*

• Shoulder Surfing (Surfista de Ombro)

Técnica de observação direta em que o atacante observa a tela, teclado ou papéis da vítima por cima do ombro para capturar senhas, PINs ou informações sensíveis.

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'attacker looks over the victim's shoulder' ou 'watches someone enter a PIN' = Shoulder surfing. Mitigação: filtros de privacidade (privacy screens).*

• Dumpster Diving (Mergulho no Lixo)

Vasculhar lixo, reciclagem ou mídia descartada para recuperar informações sensíveis como documentos impressos, post-its ou relatórios não fragmentados.

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'attacker searches through the company's trash' ou 'finds sensitive documents in a dumpster' = Dumpster diving. Mitigação: políticas de shredding e destruição de mídia.*

• Impersonação de Marca (Brand Impersonation)

Ataque em que adversários falsificam a identidade de uma empresa conhecida (Microsoft, Apple, banco, suporte técnico) via e-mail, sites ou ligações para roubar credenciais ou distribuir malware.

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'fake Microsoft support calls user' ou 'email appearing to be from a known vendor' = Brand impersonation. Distinguir de BEC: aqui é empresa externa, não executivo interno.*

• Pretexting (Pretexto)

Criar um cenário fabricado ou identidade falsa (o 'pretexto') para manipular a vítima a revelar informações ou conceder acesso, frequentemente se passando por TI, RH ou auditores.

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'attacker poses as IT support calling to reset password' = Pretexting. É a técnica-base por trás de muitas outras impersonations.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista financeiro recebe um e-mail que parece vir do nome e da foto do CEO. A mensagem diz que o CEO está em uma reunião de conselho, não pode falar e precisa de uma transferência bancária urgente para um novo fornecedor antes do fim do dia. O domínio de resposta se assemelha ao domínio da empresa, mas usa um domínio de nível superior diferente. Qual tipo de ataque de impersonação isto provavelmente é?

A) Comprometimento de e-mail corporativo (BEC)

B) Whaling

C) Impersonação de marca

D) Pretexting

QUESTÃO 2 · CENÁRIO DE EXAME

Um ator de ameaça envia um e-mail cuidadosamente elaborado ao diretor financeiro (CFO) a partir de um endereço falsificado, fingindo ser advogado externo. Ele menciona uma aquisição confidencial e pede ao CFO que abra um documento criptografado e aprove um pagamento antes da abertura do mercado. Qual categoria de impersonação melhor descreve o alvo e o método?

A) Comprometimento de e-mail corporativo (BEC)

B) Whaling

C) Tailgating

D) Shoulder surfing

QUESTÃO 3 · CENÁRIO DE EXAME

Um funcionário passa o crachá para entrar em um laboratório de pesquisa restrito. Imediatamente atrás dele, uma pessoa carregando uma caixa de papelão atravessa a porta antes que ela feche, não apresenta crachá e não é impedida. Qual risco físico de impersonação é demonstrado?

A) Shoulder surfing

B) Piggybacking

C) Tailgating

D) Dumpster diving

QUESTÃO 4 · CENÁRIO DE EXAME

A porta da sala de servidores é aberta por um funcionário que sai para o almoço. Uma pessoa com uniforme de técnico diz que deixou o crachá no carro e pede ao funcionário que segure a porta. O funcionário obedece, e a pessoa entra na área restrita. Qual ameaça de acesso físico isto melhor ilustra?

A) Piggybacking

B) Tailgating

C) Shoulder surfing

D) Dumpster diving

QUESTÃO 5 · CENÁRIO DE EXAME

Enquanto espera no portão de um aeroporto, um trabalhador remoto faz login na VPN corporativa em um notebook. Um viajante próximo inclina o telefone em direção à tela e grava o nome de usuário, a senha e o código de uso único enquanto são digitados. Qual ataque ocorreu?

A) Tailgating

B) Shoulder surfing

C) Dumpster diving

D) Impersonação de marca

QUESTÃO 6 · CENÁRIO DE EXAME

Um atacante recolhe papéis descartados na calçada em frente ao escritório de uma empresa. Os documentos incluem uma lista interna de telefones, um diagrama de rede e anotações sobre uma nova migração para a nuvem. Mais tarde, o atacante usa essas informações para ligar para funcionários fingindo ser engenheiro de TI. Qual técnica relacionada à impersonação foi usada para obter as informações?

A) Shoulder surfing

B) Pretexting

C) Dumpster diving

D) Whaling

QUESTÃO 7 · CENÁRIO DE EXAME

Funcionários recebem um e-mail de 'Microsoft 365 Support' de support@microsoft-mailbox-verify.com. Ele usa logotipos da Microsoft e avisa que a caixa de correio será desativada, a menos que façam login por um link. O link leva a uma página de login falsa. Qual tática de impersonação está sendo usada?

A) Whaling

B) Tailgating

C) Impersonação de marca

D) Dumpster diving

QUESTÃO 8 · CENÁRIO DE EXAME

Um agente de help desk recebe uma ligação de alguém que afirma ser um novo prestador de serviços. O chamador fornece um número de ticket falso e diz que está bloqueado do acesso VPN antes de uma demonstração para cliente. Ele pede que o agente redefina a conta e leia a nova senha por telefone. Qual técnica de engenharia social o chamador está usando?

A) Shoulder surfing

B) Comprometimento de e-mail corporativo

C) Pretexting

D) Dumpster diving

QUESTÃO 9 · CENÁRIO DE EXAME

O contas a pagar recebe um e-mail do endereço de um fornecedor regular. A mensagem diz que o fornecedor mudou de banco e pede que todas as faturas futuras sejam pagas em uma nova conta. A conversa inclui faturas legítimas anteriores, mas os dados bancários são diferentes. A investigação depois mostra que a caixa de correio do fornecedor foi comprometida. Qual tipo de ataque de impersonação melhor descreve isto?

A) Comprometimento de e-mail corporativo (BEC)

B) Shoulder surfing

C) Tailgating

D) Impersonação de marca

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa fornece notebooks a funcionários que trabalham frequentemente em aeroportos e cafés. A equipe de segurança quer reduzir o risco de pessoas próximas capturarem senhas e dados sensíveis das telas dos notebooks. Qual controle é mais diretamente eficaz contra essa ameaça?

A) Filtro de privacidade na tela do notebook

B) Vestíbulo de controle de acesso na entrada do escritório

C) Gateway de e-mail com aplicação de DMARC

D) Cabo de segurança preso à mesa

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Comprometimento de e-mail corporativo (BEC)

O comprometimento de e-mail corporativo (BEC) costuma usar endereço falsificado ou semelhante de executivo para pressionar o setor financeiro a fazer pagamentos urgentes. Whaling tem como alvo os próprios executivos; impersonação de marca abusa de uma marca corporativa; e pretexting é a história fabricada usada dentro do BEC.

Questão 2: Alternativa B — Whaling

Whaling é spear phishing direcionado a executivos sêniores, como um CFO. O atacante se passa por advogado externo e usa uma aquisição confidencial para tornar o pedido crível. BEC normalmente envolve se passar por um executivo para atingir o financeiro, enquanto tailgating e shoulder surfing são ataques físicos ou visuais.

Questão 3: Alternativa C — Tailgating

Tailgating ocorre quando uma pessoa não autorizada segue um funcionário autorizado por uma porta controlada sem que o funcionário permita conscientemente. Piggybacking envolveria o funcionário segurando ou escorando a porta intencionalmente para a pessoa não autorizada.

Questão 4: Alternativa A — Piggybacking

Piggybacking ocorre quando um funcionário autorizado permite conscientemente que uma pessoa não autorizada entre em uma área restrita. A desculpa do técnico é pretexting, mas a ameaça de acesso físico é piggybacking. Tailgating seria a entrada sem o consentimento do funcionário.

Questão 5: Alternativa B — Shoulder surfing

Shoulder surfing é a observação visual direta ou gravação de informações sensíveis, como credenciais ou códigos MFA, perto da vítima. Um filtro de privacidade ou proteger a tela reduz o risco.

Questão 6: Alternativa C — Dumpster diving

Dumpster diving é obter informações de documentos ou mídias descartados. A ligação posterior pode envolver pretexting, mas a pergunta é sobre como as informações foram obtidas, que foi por dumpster diving.

Questão 7: Alternativa C — Impersonação de marca

Impersonação de marca imita uma empresa ou serviço confiável, neste caso a Microsoft 365, para fazer uma página de phishing parecer legítima. Whaling tem como alvo executivos; tailgating e dumpster diving são físicos.

Questão 8: Alternativa C — Pretexting

Pretexting usa uma identidade e um cenário fabricados, como um novo prestador com ticket falso, para manipular o help desk e redefinir credenciais. O ataque é engenharia social por voz, não BEC nem shoulder surfing.

Questão 9: Alternativa A — Comprometimento de e-mail corporativo (BEC)

BEC inclui comprometimento de e-mail de fornecedor, no qual a caixa de correio de um fornecedor confiável é comprometida ou falsificada para redirecionar pagamentos. Impersonação de marca imitaria uma marca como a Microsoft, não uma conversa de fornecedor conhecido.

Questão 10: Alternativa A — Filtro de privacidade na tela do notebook

Um filtro de privacidade limita o ângulo de visão da tela do notebook, dificultando que pessoas próximas capturem senhas ou dados. Um vestíbulo de controle de acesso mitiga tailgating; DMARC mitiga falsificação de e-mail; e um cabo de segurança mitiga roubo.